

CyberSec-LLM

Fine-Tuning a Compact, Domain-Specialized Language Model
for Red/Blue Team Cybersecurity Training

Technical Report — Model Architecture, Data, Training, and Evaluation

Private, on-premises inference

Parameter-efficient fine-tuning · 4-bit quantization · instruction alignment

Objective	A small ($\leq 3\text{B}$) instruction-tuned model specialized for the domain
Method	QLoRA (4-bit NF4 base + low-rank adapters) supervised fine-tuning
Base family	Decoder-only transformer, open-weight, 0.5B–3B parameters
Deployment	Quantized artifact served locally behind the platform LLM gateway
Guarantee	No training data or inference traffic leaves the institution network

Contents

1	Introduction and Motivation	2
2	Design Goals and Constraints	2
3	Model Architecture	2
4	Data Engineering	3
4.1	Corpus composition	3
4.2	Data hygiene pipeline	3
5	Fine-Tuning Methodology: QLoRA	4
5.1	Low-rank adaptation (LoRA)	4
5.2	4-bit base (NF4) and paged optimization	4
5.3	Hyperparameters	5
6	Training Pipeline	5
7	Alignment and Safety	5
8	Quantization and Footprint	5
9	Evaluation Protocol	6
10	Inference and Integration	6
11	Compute Budget	7
12	Reproducibility and Governance	7
13	Limitations and Future Work	7

1 Introduction and Motivation

Large general-purpose language models are unnecessary—and operationally undesirable—for a supervised cybersecurity training lab. The workload is narrow and structured: proposing a next reconnaissance/exploitation step, triaging a SIEM alert into a labelled verdict, mapping activity to a MITRE ATT&CK technique, and grading a report against a rubric. These are *format-constrained, domain-bounded* tasks that a **compact model** can perform well once specialized.

We therefore train **CyberSec-LLM**: a small decoder-only transformer ($\leq 3\text{B}$ parameters) adapted with parameter-efficient fine-tuning on a curated cybersecurity instruction corpus. The design targets three properties simultaneously:

1. **Privacy by construction.** Training and inference execute on institution-controlled hardware; no data egresses the network.
2. **Task fidelity.** The model reliably emits the strict JSON contracts the platform parses, cites ATT&CK identifiers, and refuses out-of-scope requests.
3. **Commodity footprint.** A quantized 1.5B–3B model runs at interactive latency on modest CPU/GPU hardware.

2 Design Goals and Constraints

Requirement	Design consequence
On-prem, no egress	Open-weight base; local fine-tune; local inference endpoint only.
Small parameter count	Base in the 0.5B–3B range; decoder-only; grouped-query attention where available.
Interactive latency	4-bit weight quantization; short context ($\leq 4\text{k}$) for copilots; KV-cache reuse.
Structured outputs	Supervised fine-tuning on exact JSON schemas; constrained decoding at inference.
Reproducibility	Versioned datasets, deterministic seeds, logged prompt/version per call.
Safety	Refusal and scope-restriction examples; system-prompt hardening; no offensive payload generation.

Table 1: Requirements to design mapping.

3 Model Architecture

CyberSec-LLM uses a standard **decoder-only transformer** (autoregressive, causal self-attention). For a token sequence $x_{1:t}$ the model factorizes the joint probability as

$$p_{\theta}(x_{1:T}) = \prod_{t=1}^T p_{\theta}(x_t | x_{<t}),$$

trained to minimize the token-level cross-entropy (next-token prediction) loss

$$\mathcal{L}(\theta) = - \sum_t \log p_{\theta}(x_t | x_{<t}).$$

Each transformer block applies pre-norm multi-head (or grouped-query) attention followed by a gated feed-forward (SwiGLU) sub-layer with residual connections and rotary positional embeddings (RoPE):

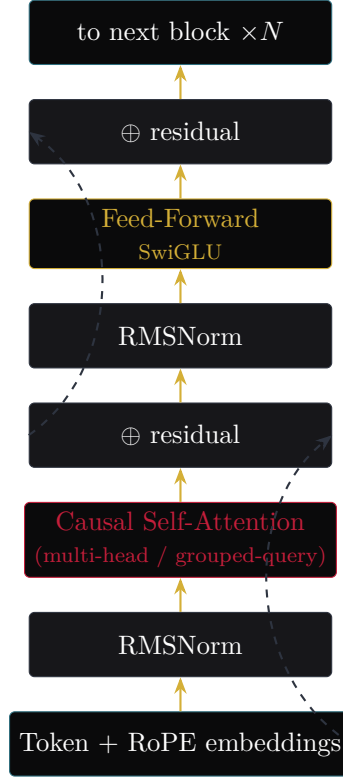


Figure 1: One pre-norm decoder block; the stack is repeated N times. Dashed arrows are residual paths.

Config	Params	Layers	d_{model}	Heads	Ctx
Tiny	0.5B	24	896	14	32k
Small	1.5B	28	1536	12	32k
Base	3.0B	36	2048	16	128k

Table 2: Representative compact base configurations (grouped-query attention, RoPE, SwiGLU).

4 Data Engineering

The corpus is the primary determinant of quality. Every example is stored in a role-tagged chat format and is designed to reproduce, verbatim, the output contract of the target platform module.

```

{"messages": [
  {"role": "system", "content": "SOC triage copilot. Reply as JSON."},
  {"role": "user", "content": "Suricata: repeated SQLi signatures, one src IP -> web server, 12x/30s."},
  {"role": "assistant", "content": "{\"verdict\": \"true_positive\", \"confidence\": 0.83, \"mitre_technique_id\": \"T1190\", \"next_step\": \"Correlate web logs; block source if confirmed.\"}"}
]}

```

Listing 1: One instruction example (chat JSONL).

4.1 Corpus composition

4.2 Data hygiene pipeline

1. **Schema validation** — every line parsed; role set and non-empty content enforced.

Task	Share	What it teaches
Pentest next-step (JSON)	25%	One safe command + ATT&CK id, kill-chain ordering.
SOC alert triage (JSON)	25%	Verdict, confidence, reasoning, response step.
MITRE tagging (JSON)	15%	Activity/rule $\rightarrow$ single technique id.
Report grading (JSON)	12%	Rubric-criterion scoring voice.
Domain Q&A (text)	15%	Concise explanatory tone.
Refusals / scope control	8%	Decline out-of-scope or unsafe requests.

Table 3: Instruction mix (target $\approx$ 1k–3k curated examples).

2. **PII / secret scrubbing** — no real credentials, tokens, or student identifiers; generic placeholders only.
3. **Deduplication** — near-duplicate removal via normalized-text hashing / MinHash to prevent memorization.
4. **Decontamination** — held-out evaluation prompts excluded from the training split.
5. **Format conformance** — JSON-target assistant turns must themselves parse as JSON.

5 Fine-Tuning Methodology: QLoRA

We use **QLoRA**—low-rank adaptation on top of a 4-bit-quantized frozen base—to specialize the model at a fraction of full fine-tuning cost.

5.1 Low-rank adaptation (LoRA)

For a pretrained weight $W_0 \in \mathbb{R}^{d \times k}$, LoRA constrains the update to a low-rank product and freezes W_0 :

$$W = W_0 + \Delta W, \quad \Delta W = \frac{\alpha}{r} BA, \quad B \in \mathbb{R}^{d \times r}, \quad A \in \mathbb{R}^{r \times k}, \quad r \ll \min(d, k).$$

The forward pass becomes $h = W_0 x + \frac{\alpha}{r} B(Ax)$. Only A, B are trained, reducing trainable parameters from dk to $r(d+k)$. With $r=16$ this is typically $< 1\%$ of model parameters.

5.2 4-bit base (NF4) and paged optimization

The frozen base is stored in 4-bit *NormalFloat* (NF4), dequantized on-the-fly during the forward/backward pass; adapter weights and optimizer states remain in higher precision. Gradient checkpointing and 8-bit optimizer states further cut memory, letting a 3B model fine-tune within a single ~ 16 GB accelerator.

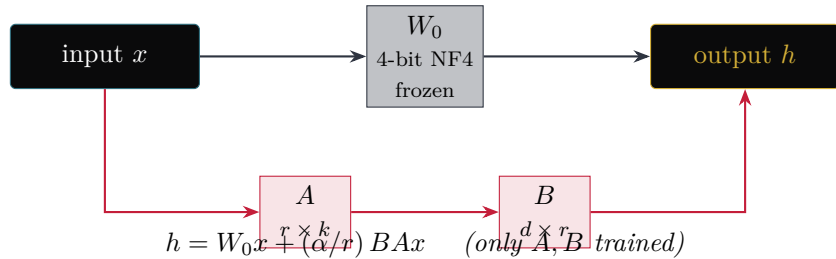


Figure 2: QLoRA: a frozen 4-bit base with trainable low-rank adapters injected into the attention/MLP projections.

5.3 Hyperparameters

Parameter	Value	Parameter	Value
LoRA rank r	16	Optimizer	AdamW (8-bit)
LoRA α	16	Learning rate	2×10^{-4}
LoRA dropout	0.0	LR schedule	linear w/ warmup
Target modules	<code>q,k,v,o,gate,up,down</code>	Epochs	2–3
Base precision	4-bit NF4	Batch (eff.)	8 (2×4 accum.)
Max seq length	4096	Weight decay	0.01
Grad checkpoint	on	Seed	fixed

Table 4: QLoRA supervised fine-tuning configuration.

6 Training Pipeline

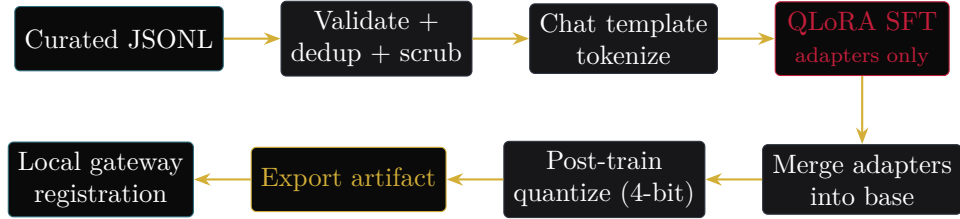


Figure 3: End-to-end pipeline: data preparation, adapter training, merge, quantization, and local registration.

7 Alignment and Safety

Because the model advises on offensive and defensive security, alignment is a first-class training objective, not an afterthought:

- **Scope restriction.** Explicit examples teach the model to refuse targets outside the isolated lab range and to never emit destructive or novel exploit payloads—only orchestration of documented tooling.
- **Human-in-the-loop framing.** The pentest task never “executes”; it proposes a single action for human approval, reinforced in every training example.
- **Contract adherence.** JSON-only targets reduce prompt-injection surface and make outputs machine-verifiable.
- **Adversarial evaluation.** The model is probed post-training with prompt-injection and jail-break suites; failures feed the next data iteration (a closed hardening loop).

8 Quantization and Footprint

Post-training weight quantization to 4-bit reduces the served artifact roughly 4× versus fp16 while preserving task accuracy for these constrained outputs. Approximate resident weight memory $M \approx N \cdot b/8$ bytes for N parameters at b bits:

Model	fp16 ($\approx$)	4-bit ($\approx$)	QLoRA train VRAM
0.5B	1.0 GB	0.30 GB	$\sim$ 4 GB
1.5B	3.0 GB	0.90 GB	$\sim$ 7 GB
3.0B	6.0 GB	1.7 GB	$\sim$ 12 GB

Table 5: Approximate weight footprint and single-accelerator training budget.

9 Evaluation Protocol

Evaluation is task-specific and automated where possible, on a decontaminated held-out split. Metrics:

- **JSON validity rate** — fraction of copilot outputs that parse against the module schema.
- **MITRE tagging accuracy** — exact-match technique id vs. gold labels.
- **SOC verdict F1** — macro-F1 over {true positive, false positive, benign} vs. faculty ground truth.
- **Refusal correctness** — correct decline on out-of-scope/unsafe prompts.
- **Perplexity** — held-out next-token loss for regression tracking.

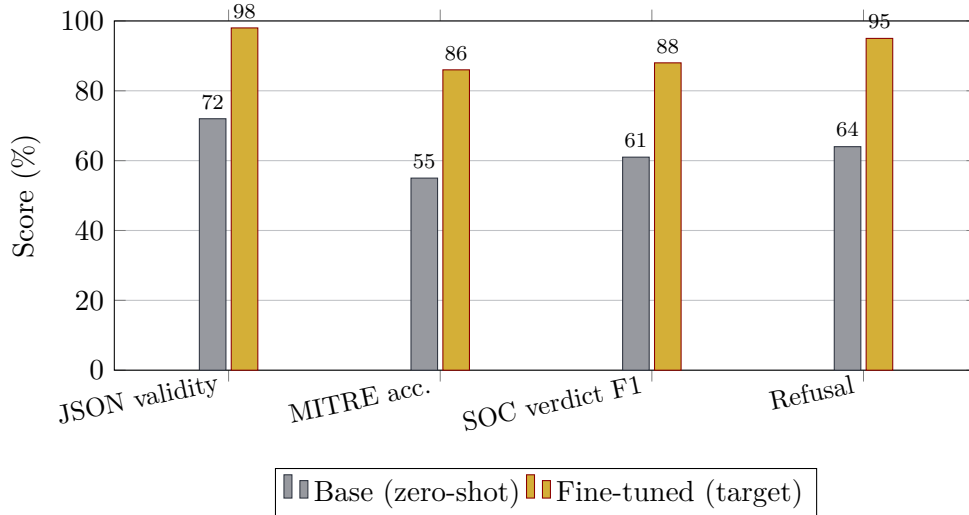


Figure 4: Acceptance targets: parameter-efficient fine-tuning chiefly improves format conformance, tagging, and refusal reliability. Values are target thresholds for release sign-off, not a claim of a specific trained checkpoint.

10 Inference and Integration

The released artifact is served on institution hardware behind the platform’s LLM gateway over an HTTP interface; no third-party service is contacted. The gateway performs module-aware routing, injects the versioned system prompt, enforces a per-session token budget, and logs the full prompt/completion pair with the prompt version for reproducibility. Inference-time reliability is further improved with constrained/JSON-guided decoding and a low sampling temperature for the structured tasks.

11 Compute Budget

- **Training** (one-time, per model version): a single mid-range accelerator; on the order of 1–3 GPU-hours for 1.5B–3B with QLoRA on a few thousand examples.
- **Inference** (continuous): a 4-bit 1.5B–3B model runs at interactive latency on a modest GPU, and acceptably on multi-core CPU for the short-context copilot tasks.

12 Reproducibility and Governance

Every model version is tied to (i) an immutable dataset snapshot, (ii) the exact hyperparameter set and random seed, and (iii) a registry entry recording the served model name and the system-prompt version. Because the platform logs the prompt version and model on every call, any graded artifact can be reproduced and audited—an explicit requirement for accreditation evidence.

13 Limitations and Future Work

- Fine-tuning primarily shapes *style, format, and domain grounding*; factual recall is better served by retrieval augmentation over a curated knowledge base.
- Small models have finite reasoning depth; complex multi-step exploitation reasoning should remain human-supervised.
- Planned: preference optimization (DPO) on faculty-rated outputs; retrieval-augmented generation over ATT&CK and course materials; distillation from a larger local teacher; per-technique attainment calibration.

End of technical report — CyberSec-LLM.